Lab 7.2 : VoucherDFD และ STRIDE

ผลงานผู้เรียน • 18 ตุลาคม 2026 • **Design proposal : ยังไม่ implement และยังไม่รัน fixture**

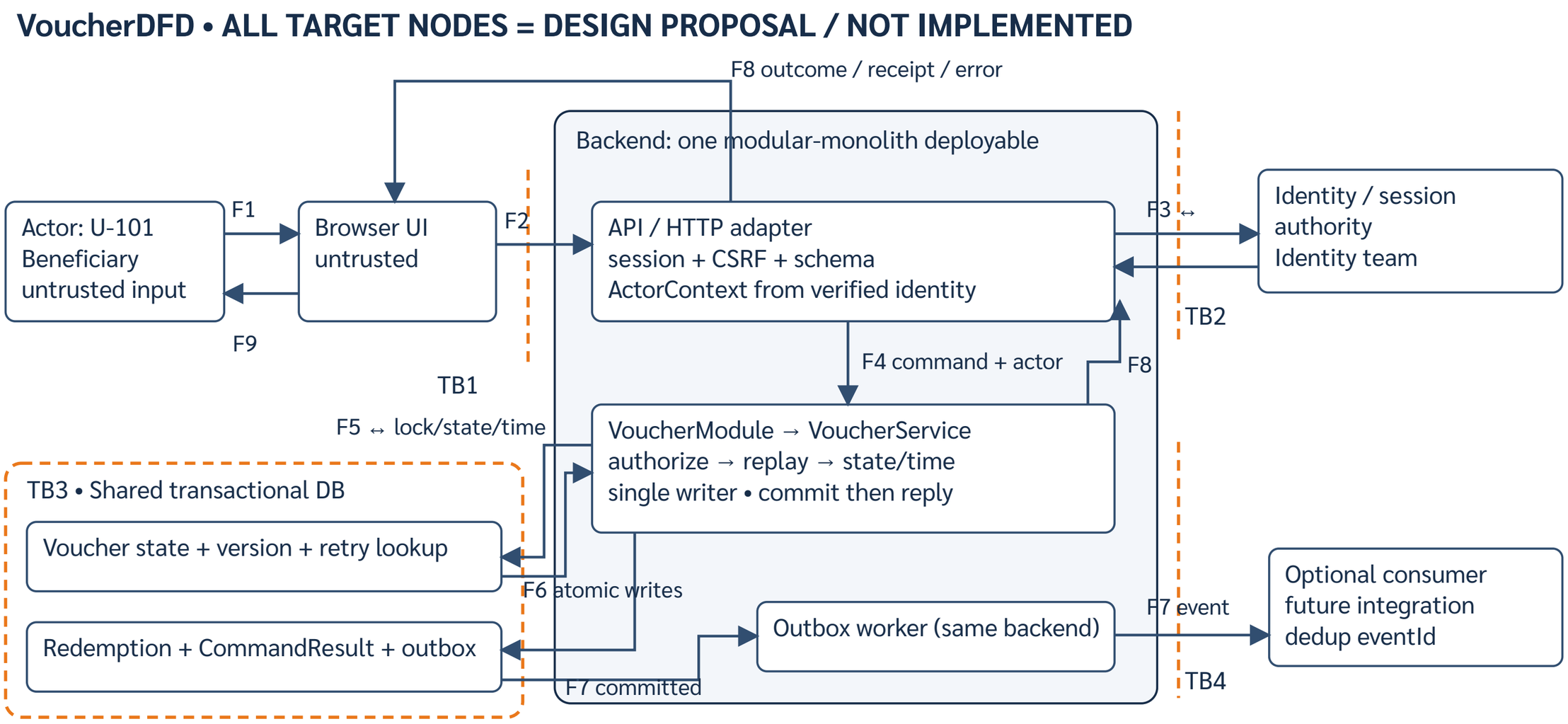
1. ฐานงานและขอบเขตหลักฐาน

ใช้ source-adr.md, source-dfd.md, source-contract.md, source-control-result.md และ source-diagram.svg เป็นหลักฐานเดิม; รับ decision จาก ADR7.1 คง ADR-VOUCHER-0001: modular monolith; VoucherService เป็น command service ภายใน VoucherModule ไม่ใช่ separate service. Voucher domain team เป็น data owner และ VoucherModule เป็น writer เดียว; worker อยู่ backend deployable เดียว; shared DB แยก container; consumer เป็น optional future integration.

Case เดิม: V-001 / issuer ISS-01 / beneficiary U-101 / operator OP-01 ของ ISS-01; เริ่ม ISSUED, clock=2026-10-18T00:00:00Z, expiresAt=2026-10-20T00:00:00Z. ต้อง activate ก่อน redeem; REDEEMED/CANCELLED เป็น terminal; EXPIRED derived เมื่อ now≥expiresAt. Success คือ committed consumption หนึ่งครั้ง ไม่ใช่จำนวน responses/deliveries.

Confirmed จากเอกสาร: target architecture, ownership และ semantics ข้างต้น ไม่ใช่ runtime confirmation; scope W8 อ้าง baseline source แยกใน §4. **Proposed:** UI/API/session/DB/outbox และ C1–C3 ทั้งหมด. **Assumptions ที่ต้องยืนยันกับ owners:** issuer-as-tenant, แหล่ง role/membership, code lifecycle, replay archival และ timeout 2s/5s. รายละเอียด baseline ต่อไปนี้อ้างตาม source-adr.md และ source-contract.md; รอบนี้ไม่ได้เปิด baseline หรือรัน fixture จึงไม่มี exploit result. Target design ไม่ใช่ fixture implementation.

2. DFD ของ redeem : design proposal



เปิด SVG เต็ม. ทุก node ใน target model เป็น proposal. กรอบ W8 ในภาพเป็น source-confirmed scope: harness ส่ง code/actor/now/checkpoint → VoucherService → in-memory records/events → Redemption. actor เป็น caller label ไม่ใช่ auth; ไม่มี UI/HTTP/auth/DB/worker/consumer. F1–F9 เป็น target flows; fixture ครอบเฉพาะส่วน service/state/event/result ไม่ใช่ F3 authorization หรือ F6 outbox. Team Notes DFD เป็นเพียงตัวอย่างวิธีวาด ไม่ใช่ DFD case นี้.

Flow ID	Data / direction และ trust
F1	Beneficiary → UI: voucherId, requestId, optional clientReference; input ไม่เชื่อถือ. Beneficiary ใช้ activate/redeem; issuer operator ใช้ cancel เท่านั้น
F2	UI → API: proposed POST /vouchers/{id}/redeem + session cookie/CSRF; ข้าม TB1. ไม่รับ actorId/state/expiry/issuer จาก body; code ไม่ใช่สิทธิ์
F3	API ↔ identity/session authority: ตรวจ session/lifetime และ trusted subject/roles/issuerMemberships; ข้าม TB2
F4	API → VoucherService ใน VoucherModule: validated command + ActorContext; logical interface ภายใน backend ไม่ใช่ network isolation
F5	Service ↔ state store: lock/read voucher + retry key; authorize จาก stored beneficiary/issuer ก่อนเปิดเผย state/receipt; ตรวจ server UTC หลัง lock แล้ว update state/version
F6	Service → redemption + CommandResult + outbox: atomic กับ F5 ใน TB3 transaction; eventId/receipt คงที่ ไม่ใส่ code/token
F7	committed outbox → worker → optional consumer: at-least-once ผ่าน TB4; delivery ซ้ำได้ consumer dedup eventId
F8	Service → API → UI: outcome/receipt หลัง commit หรือ error ที่ไม่มี receipt; HTTP mapping เป็น proposal
F9	UI → actor: แสดง REDEEMED/REPLAY หรือ error; response หายไม่แปลว่า rollback ต้อง retry key เดิม

TB1 browser/backend: UI team + Voucher team ดูแล schema/policy. TB2 identity/backend: Identity team ดูแล credentials/membership. TB3 backend/DB: Voucher team ดูแล transaction และ writer-only access; Platform ดูแล credentials/infrastructure. TB4 worker/consumer: Voucher + consumer teams ดูแล delivery/dedup. UI ไม่เป็น authority; event ไม่ให้สิทธิ์แก้ voucher.

ข้อมูล flow และ ownership ที่จำเป็น (ไม่มี dependency ต่อเอกสาร Data/API Contract)

สายส่งมอบมีเพียง **ADR7.1 → DFD7.2 → Control7.3**. Control7.3 และ VoucherControlContract รับ F1–F9/T1–T2 จาก DFD นี้โดยตรง.

ข้อมูล	Target proposal / authority	W8 ตามหลักฐานเดิม
code / identity	voucherId=V-001 ใช้ lookup ไม่ใช่สิทธิ์; issuerId=ISS-01, beneficiaryId=U-101 เป็น stored data ของ VoucherModule	code ใน records; แต่ละ probe ใช้ code และ service ของตน
actor / owner	Verified ActorContext จาก Identity team; beneficiary activate/redeem, issuer operator cancel	actor=alice/bob เป็น caller label ไม่มี auth/role; activate/cancel ไม่มี actor argument
time	VoucherModule ตรวจ server UTC หลัง lock; expiresAt เป็น stored data; now=expiry ต้อง reject	trusted integer now=10, expires_at=100; ไม่มี clock/auth proof
state	ISSUED→ACTIVE→REDEEMED; ISSUED/ACTIVE→CANCELLED; terminal ไม่ reset, expiry derived	issued/active/cancelled/expired/used; snapshot มี redeemed_by/redemption_count
result / event	F8/F9 คืน outcome/receipt หลัง atomic commit; F6 เก็บ Redemption/CommandResult/outbox; F7 delivery อาจซ้ำ	Redemption(ok, reason, receipt_id, actor); events={code, actor, receipt_id}; repeated consume reject ไม่มี event ใหม่

แก้ความหมาย caller ให้ตรง ADR7.1: beneficiary activate/redeem; issuer operator cancel เท่านั้น ไม่ได้ activate หรือ redeem แทน beneficiary. Voucher domain team เป็น accountable owner ของข้อมูลและ control contract; VoucherModule เป็น writer เดียว.

C1 = verified actor + stored resource policy (Identity/Voucher teams). C2 = stored state/time guard + atomic once-only transition และ target durable outbox (Voucher team; Platform สนับสนุน DB). C3 = stable committed receipt, same-key transport retry และ consumer eventId dedup (Voucher/consumer teams); ทั้ง C1 และ transport C3 อยู่นอก W8. รายละเอียด P1–P5 และ risk response อยู่ Control7.3 ไม่ต้องอ่านเอกสาร contract อีกข้อก่อนหน้า.

3. Threat hypotheses และ control trace

Threat / STRIDE / flows	Preconditions และ invariant ที่เสี่ยง	Impact / proposed controls	Evidence และ missing evidence
T1 : state/time tampering หรือ stale validation; Tampering (T), Elevation of Privilege (E) เมื่อข้าม policy; F2–F6, TB1–3	ผู้เรียกส่ง state/time/owner ปลอม หรือ actor ไม่มีสิทธิ์; service เชื่อ input, ใช้ time ก่อนรอ lock หรือเปิด writer ทางอื่น. ละเมิด authorized ∧ ACTIVE ∧ now<expiresAt และ terminal rule	Consume ก่อน activate/หลัง cancel/deadline หรือข้าม owner. **C1** trusted actor/scoped policy; **C2** stored state + server clock หลัง lock + writer-only transaction; **P1/P2/P5** ใน contract	Static baseline: redeem ไม่ guard issued/cancelled/expired หรือ now≥expires_at. Probe state/cancel/expiry มีแล้วแต่ยังไม่รัน. Actor authorization/schema/DB evidence ไม่มีและอยู่นอก fixture; ไม่อ้าง exploit สำเร็จ
T2 : replay/race และ partial commit; Tampering (T) ต่อ redemption integrity; F4–F9, TB3–4	legitimate caller retry หลัง response หายหรือหลาย callers แข่งกัน; check/write ไม่ atomic, dedup หลุด transaction, หรือ consumer เชื่อ delivery ว่าเป็น success ใหม่	Redemption ซ้ำ, state/event ไม่ตรง, external side effect ซ้ำ. **C2** atomic state/redemption/result/outbox + uniqueness; **C3** stable replay/retry + consumer dedup; **P3/P4/P5**	Static baseline: used ถูก reject เฉพาะ actor ต่างคน และ check/commit แยก lock. replay/race probes มีแล้วแต่ยังไม่รัน. Fault/DB restart/consumer tests เป็น future target plans ไม่มีใน W8

STRIDE ใช้จำแนกวิธีละเมิด ไม่แทน business invariant. T1/T2 เป็น hypotheses ไม่ใช่ Sonar issue หรือ vulnerability ที่ยืนยันแล้ว. C1–C3 นิยามใน §2 ของ DFD นี้และ VoucherControlContract.

4. Review และ handoff

ตรวจ actors/flows เทียบเอกสารต้นทางแล้ว: ไม่มี endpoint ที่อ้างว่าค้นพบ, ไม่เพิ่มบริการแยก, actor ไม่ได้ส่งสิทธิ์เอง, F5/F6 เป็น transaction เดียว และ F8 ไม่ออก success ก่อน commit. การตรวจนี้เป็น document consistency review โดยผู้เรียน ไม่ใช่ owner approval; assumptions ยังเปิดอยู่.

ส่ง diagram.svg + result.md ให้ Lab 7.3: T1→state/cancel/expiry เทียบ positive; T2→replay/race เทียบ positive; unknown ตรวจ lookup boundary. ใช้ probes เดิมเท่านั้นตาม ADR7.1 §7; C1/C3 และ P5 auth เป็น target-only. P3 ของ fixture คือ reject repeat ไม่ใช่ transport idempotency. F5/F6 เฉพาะ check/state/event effect เทียบได้กับ memory ไม่ใช่ DB/outbox.

Public API คือ redeem(code, actor, now, checkpoint=None); response Redemption(ok, reason, receipt_id, actor). Record ใช้ code/expires_at/state/redeemed_by, states lowercase (used แทน target REDEEMED); NOW=10, EXPIRES_AT=100. snapshot มี redemption_count, events มี code/actor/receipt_id เท่านั้น; ไม่แยก Activated event เพราะไม่มี. Same-voucher same-actor retry ต้อง reject/already_used ไม่เพิ่ม event. Race ใช้ shared service สอง threads ใน isolated child process; checkpoint_calls=2, errors=[], success_count=event_count=1 เป็น expected; observation ไม่ครบคือ inconclusive. ขณะนี้ not run. ไม่มี role/tenant/requestId/CommandResult/outbox/fault injection หรือ distributed proof และไม่กำหนดให้เพิ่ม probes.

เนื้อหางาน	จุดส่งมอบ
DFD, data/identity/boundaries/sc	§1–2 และ diagram.svg มี actor/UI/API/service/state/event/response พร้อม F1–F9, TB1–4

เนื้อหางาน	จุดส่งมอบ
ope	
Context และ document review	§1 แยก confirmed/proposed/assumptions; §4 ตรวจจากเอกสาร ไม่มีการอ้าง reviewer อื่นอนุมัติ
Threats T1/T2	§3 มี STRIDE, preconditions, impact, missing evidence และ control/invariant links
Scope / evidence	Case Voucher เดิม; design-only ไม่ patch/scan ไม่สวม Team Notes/BOLA หรือผล in-memory เป็น HTTP/auth/DB proof